Tahdid razvedaksi: Email phishing bo’yicha

Tahlilchi Hunter: Nazarov Zabihullo
Aloqa: +998 33 737 37 03 (Telegram: @Nazarov_Zabihullo)

---

1. Ushbu hujum qaysi APT guruhiga tegishli?

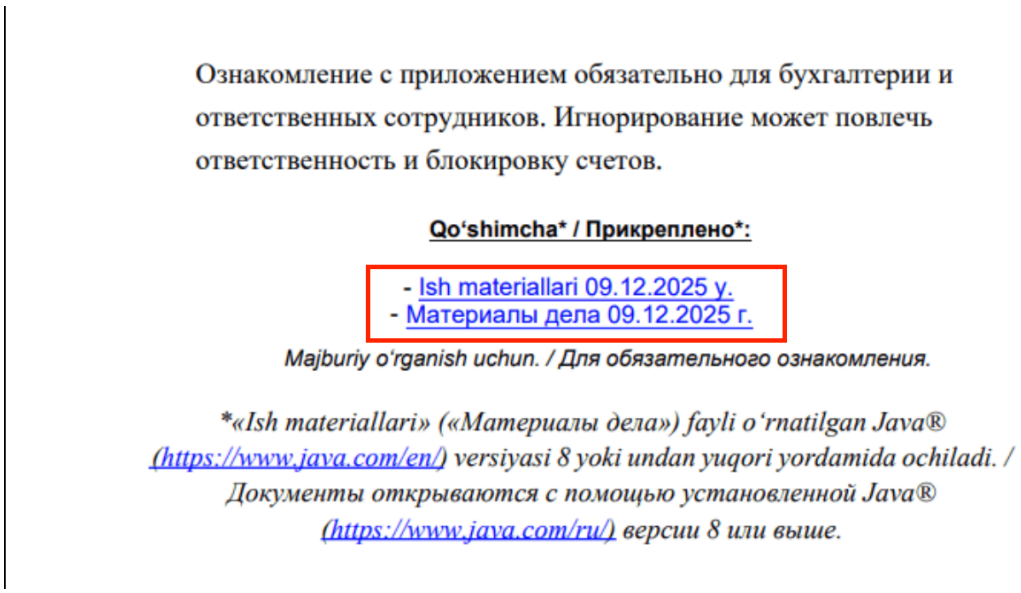
Ushbu hujum Stan Ghouls (oldingi nomi Bloody Wolf) ga tegishli.

manba: https://thehackernews.com/2025/11/bloody-wolf-expands-java-based.html
https://cyberpress.org/bloody-wolf-deploys-netsupport/

2. Nima uchun hujumchi aynan Java Runtime o‘rnatilishini talab qilgan?

Sabab zararli yuklamalar va JAR fayllar ishlay olishi uchun, chunki windowsda default xolatda Java muhiti bo’lmaydi.

Zararli JAR loader fayili emaildan yuborilgan **E-SUD_705306256_Ijro_varaqasi.pdf** nomli faylda berilgan havolaga joylashtirilgan



Ознакомление с приложением обязательно для бухгалтерии и ответственных сотрудников. Игнорирование может повлечь ответственность и блокировку счетов.

Qo‘shimcha* / Прикреплено*:

- Ish materiallari 09.12.2025 y.
- Материалы дела 09.12.2025 г.

Majburiy o‘rganish uchun. / Для обязательного ознакомления.

**«Ish materiallari» («Материалы дела») fayli o‘rnatilgan Java® (https://www.java.com/en/) versiyasi 8 yoki undan yuqori yordamida ochiladi. / Документы открываются с помощью установленной Java® (https://www.java.com/ru/) версии 8 или выше.*

Ikkta havola ham bir zararli JAR faylga yo’naltiradi
(MD5:95db93454ec1d581311c832122d21b20).

3. Xodim qabul qilgan malware nomi nima?

xodim qabul qilgan malware bu **NetSupport RAT** bo'lib nomi **client32.exe**, undan tashqari xodim boshqa zararli fayllarni ham yuklab olgan bo'lishi mumkin: **PCICHEK.DLL, advpack.dll, msvcr100.dll, remcmdstub.exe, ir50_qcx.dll, client32.ini, AudioCapture.dll, kbdlk41a.dll, KBDSF.DLL, tcctl32.dll, HTCTL32.DLL, kbdibm02.DLL, kbd101c.DLL, kbd106n.dll, ir50_32.dll, nskbfltr.inf, NSM.lic, pcicapi.dll, PCICL32.dll, qwave.dll.**

manba: https://securelist.com/stan-ghouls-in-uzbekistan/118738/

4. Loader to'xtashidan oldin nechta ishga tushirish urinishini amalga oshiradi?

Loader 3 ta urinish limitini qo'yadi va 3 urinishga yetganda to'xtaydi. Bu zararli fayl uchun antivirus va sandbox'ni aldash uchun shu bilan birga user'ni chalg'itish uchun kerak ekan.

5. Ushbu malware ishlatgan persistence mexanizmlarini sanab bering va ularni MITRE ATT&CK texnikalari bilan bog'lang

Mexanizm	MITRE ATT&CK ID	Texnik detal
Windows Startup Folder	T1547.001 - Boot/Logon Autostart: Startup Folder	Drops SoliqUZ_Run.bat into %AppData%\Roaming\Microsoft\Windows\Start Menu\Programs\Startup
Registry Run Key	T1547.001 - Boot/Logon Autostart: Registry Run Keys	HKCU\Software\Microsoft\Windows\CurrentVersion\Run > run.bat
Scheduled Task (ONLOGON)	T1053.005 - Scheduled Task/Job: Scheduled Task	schtasks /TN malicious /TR run.bat /SC ONLOGON - triggers on every user login

6. Ushbu malware kampaniyasi orqali jami nechta nishon komprometatsiya qilingan?

Jami kompremetatsiya qilingan nishonlar soni 60 tadan ko’proq (50 ta O’zbekistonda, 10 ta Rossiyada va Qozog‘iston, Turkiya, Serbiya hamda Belarussiyada yana bir nechta qurbonlar bor.

MITRE ATT&CK To’liq xarita (Full Mapping)

Taktika	Texnik ID	Texnik nomi	Amalga oshirish nuqtasi
Initial Access	T1566.002	Phishing: Spearphishing Link	Email with malicious link posing as court documents
Execution	T1059.007	Command & Scripting: JavaScript/JScript	Malicious JAR loader execution
Execution	T1204.002	User Execution: Malicious File	Victim manually runs the JAR file
Execution	T1059.003	Command & Scripting: Windows Command Shell	run.bat / SoliqUZ_Run.bat executes client32.exe
Persistence	T1547.001	Boot/Logon Autostart: Registry Run Keys & Startup Folder	Startup folder + HKCU Run key
Persistence	T1053.005	Scheduled Task/Job: Scheduled Task	schtasks on ONLOGON trigger
Defense Evasion	T1036	Masquerading	Legitimate signed NetSupport binary (client32.exe)
Defense Evasion	T1027	Obfuscated Files or Information	JAR loader with hardcoded single-class structure
Defense Evasion	T1480.001	Execution Guardrails: Environmental Keying	Geofencing: only Uzbek IPs receive malicious payload
C&C	T1219	Remote Access Software	NetSupport Manager as C2 channel
C&C	T1071.001	App Layer Protocol: Web Protocols	HTTP/HTTPS connections to C2 via NetSupport
Collection	T1113	Screen Capture	NetSupport RAT live screen monitoring capability
Collection	T1056.001	Input Capture: Keylogging	NetSupport RAT keylogging capability
Exfiltration	T1041	Exfiltration Over C2 Channel	Data theft via NetSupport RAT session
Impact	T1657	Financial Theft	Primary goal: banking/financial fraud

IoC Ro’yxati

1. Fayllar (hesh)

PDF 7556e2f5a8f7d7531f28508f718cb83d (E-SUD_705306256_ljro_varaqasi.pdf)
JAR 95db93454ec1d581311c832122d21b20 (custom JAR dropper)
INI edfb8d26fa34436f2e92d5be1cb5901b (client32.ini / versiya A)
INI 3e86f6fc7ed037f3c9560cc59aa7aacc (client32.ini / versiya B)
INI ae4d6812f5638d95a82b3fa3d4f92861 (client32.ini / versiya C)

2. Zararli domenlar

mysoliq-uz[.]com
my-xb[.]com
xarid-uz[.]com
ach-uz[.]com
soliq-uz[.]com
minjust-kg[.]com
esf-kg[.]com
taxnotice-kg[.]com
notice-kg[.]com
proauditkg[.]com
kgaudicheck[.]com
servicedoc.kg-auditcheck[.]com
servicedoc.kg-notice-com.rouming-uz[.]com
audit-kg[.]com
kyrgyzstanreview[.]com
salyk-notofocations[.]com
hgame33[.]com
xoomep1[.]com:1935
xoomep2[.]com:1935
golden-scalen[.]com

3. IP Manzillar

31[.]44[.]4[.]40 payload'ni yetkazib beruvchi host bat_install.bat - versiya A
188[.]227[.]58[.]243 payload'ni yetkazib beruvchi www.php + install BAT - versiya B/C
188[.]227[.]106[.]124 JS payload'ni yetkazib beruvchi va payload hosti - versiya C
45[.]133[.]16[.]135 payload'ni yetkazib beruvchi host - versiya D
193[.]42[.]32[.]138 BurnsRAT C2 BurnsRAT API endpoint
87[.]251[.]67[.]51 BurnsRAT C2 BurnsRAT API backup

4. Fayl nomlari va Artifaktlar

client32.exe (NetSupport RAT main executable)

client32.ini (NetSupport C2 configuration)
NSM.LIC (NetSupport license file)
run.bat (Batch file created by loader to launch RAT)
SoliqUZ_Run.bat (Startup persistence batch file. Startup folder)
PCICHEK.DLL (NetSupport component DLL)
HTCTL32.DLL (NetSupport HTTP transport DLL)
E-SUD_705306256_ljro_varaqasi.pdf (Decoy legal document displayed to victim, embedded in JAR)
bat_install.bat (Earlier variant installation script)

5. Registry keys'lar

HKCU\Software\Microsoft\Windows\CurrentVersion\Run → run.bat
Startup: %AppData%\Roaming\Microsoft\Windows\StartMenu\Programs\Startup\SoliqUZ_Run.bat
Scheduled Task nomi: malicious